

CSE 331: Computer Security Fundamentals

Spring 2026

Asymmetric Encryption:
Certificates, Public Key Infrastructure (PKI)

Amir Rahmati
Xinrui Yu

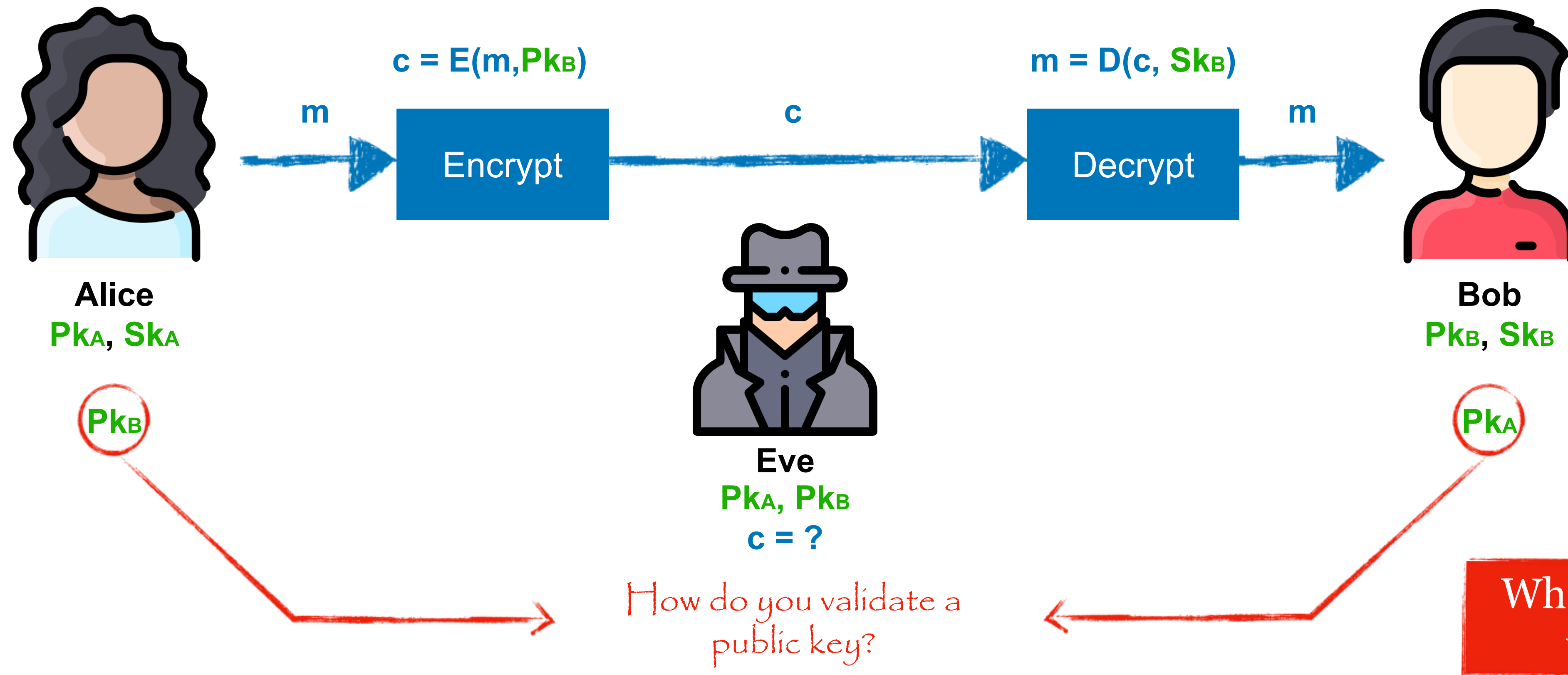


Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

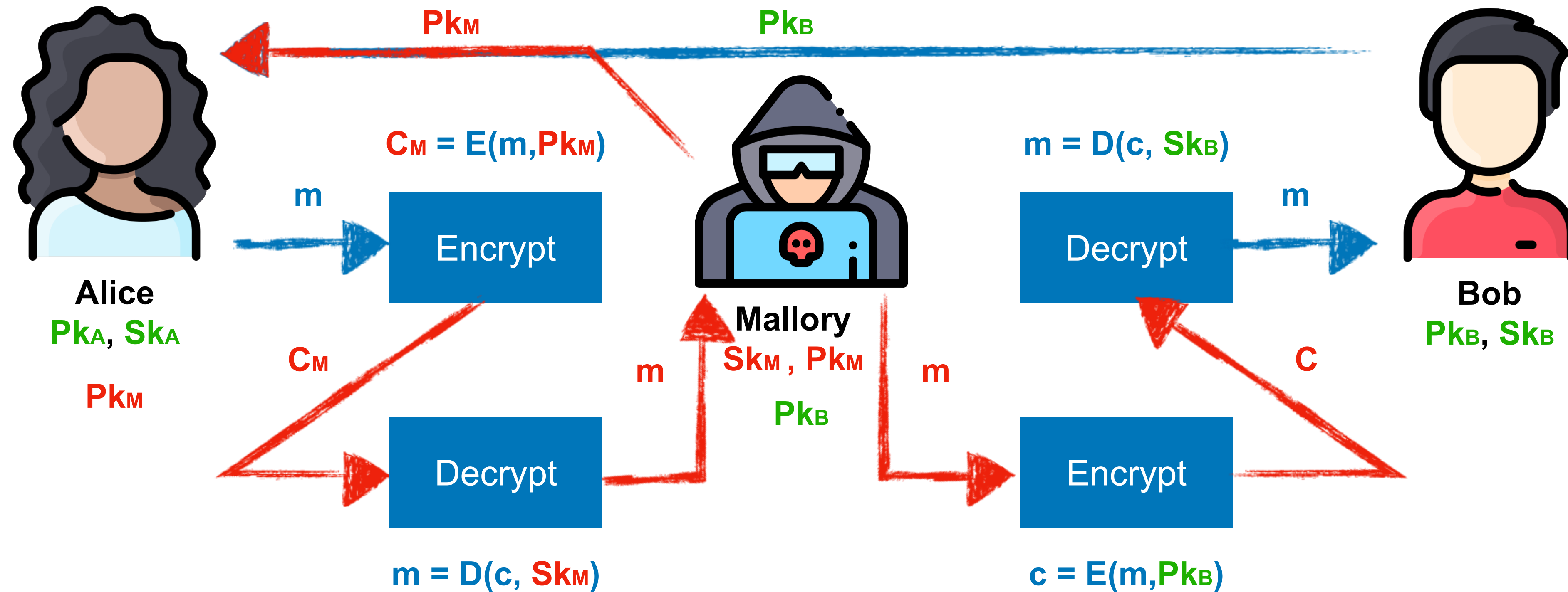
Asymmetric Setting

Each party creates a public key Pk and a secret key Sk .

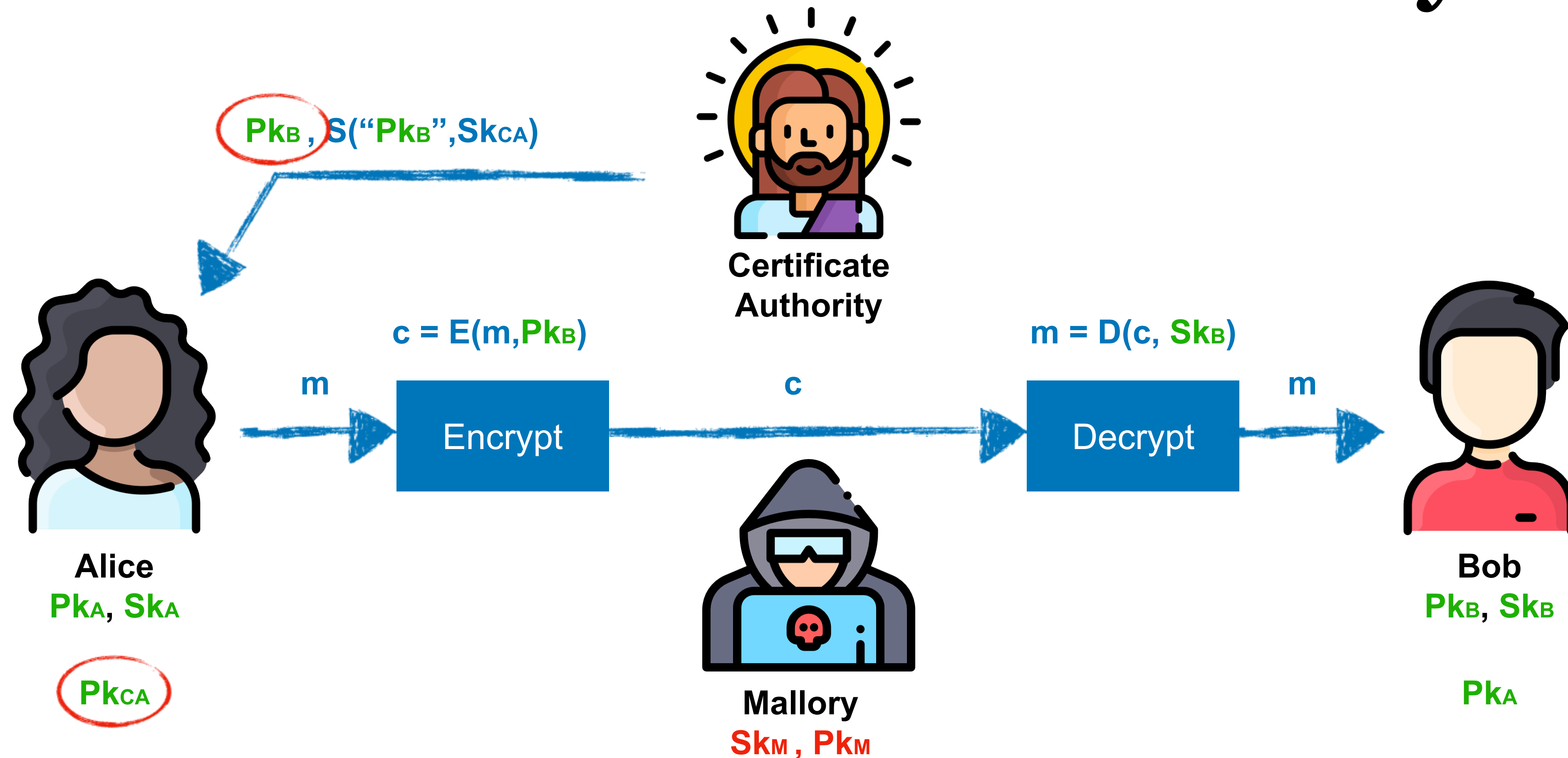


Man-in-the-Middle (MITM)

Neither Alice, nor Bob can tell that something has gone wrong!



Distribution of Public Keys



- After generating a private/public key pair, user **proves their identity** and **knowledge of the private key** to obtain CA's certificate for the public key
- Every computer is **pre-configured with CA's public key**

Trusted(?) Certificate Authorities

The screenshot displays the macOS Keychain Access application. The left sidebar shows the 'System Roots' keychain selected under the 'Certificates' category. The main pane lists various root certificates, with 'DST Root CA X3' highlighted. An overlay window provides detailed information for this specific certificate.

Keychain Access Interface:

- Keychains:** login, iCloud, System, System Roots (selected)
- Category:** All Items, Passwords, Secure Notes, My Certificates, Keys, Certificates
- System Roots List:**

Name	Kind	Date Modified	Expires	Keychain
DigiCert Assured ID Root CA	certificate	--	Nov 9, 2031 at 7:00:00 PM	System Roots
DigiCert Assured ID Root G2	certificate	--	Jan 15, 2038 at 7:00:00...	System Roots
DigiCert Assured ID Root G3	certificate	--	Jan 15, 2038 at 7:00:00...	System Roots
DigiCert Global Root CA	certificate	--	Nov 9, 2031 at 7:00:00 PM	System Roots
DigiCert Global Root G2	certificate	--	Jan 15, 2038 at 7:00:00...	System Roots
DigiCert Global Root G3	certificate	--	Jan 15, 2038 at 7:00:00...	System Roots
DigiCert High Assurance EV Root CA	certificate	--	Nov 9, 2031 at 7:00:00 PM	System Roots
DigiCert Trusted Root G4	certificate	--	Jan 15, 2038 at 7:00:00...	System Roots
DST Root CA X3	certificate	--	Sep 30, 2021 at 10:01:15...	System Roots
E-Tugra Certification Authority	certificate	--	Mar 3, 2023 at 7:09:48 AM	System Roots
Echoworx Root CA2	certificate	--	Oct 7, 2020 at 6:49:13 AM	System Roots
EE Certification Centre Root CA				
Entrust Root Certification Authority				
Entrust Root Certification Authority - EC1				
Entrust Root Certification Authority - G2				
Entrust.net Certification Authority (2048)				
ePKI Root Certification Authority				
GDCA TrustAUTH R5 ROOT				
GeoTrust Global CA				
GeoTrust Primary Certification Authority				
GeoTrust Primary Certification Authority - G2				
GeoTrust Primary Certification Authority - G3				
Global Chambersign Root				
Global Chambersign Root - 2008				
GlobalSign				
GlobalSign				
GlobalSign				
GlobalSign				
GlobalSign Root CA				
Go Daddy Class 2 Certification Authority				
Go Daddy Root Certificate Authority - G2				
Government Root Certification Authority				
GTS Root R1				
GTS Root R2				
GTS Root R3				

Detailed View of DST Root CA X3:

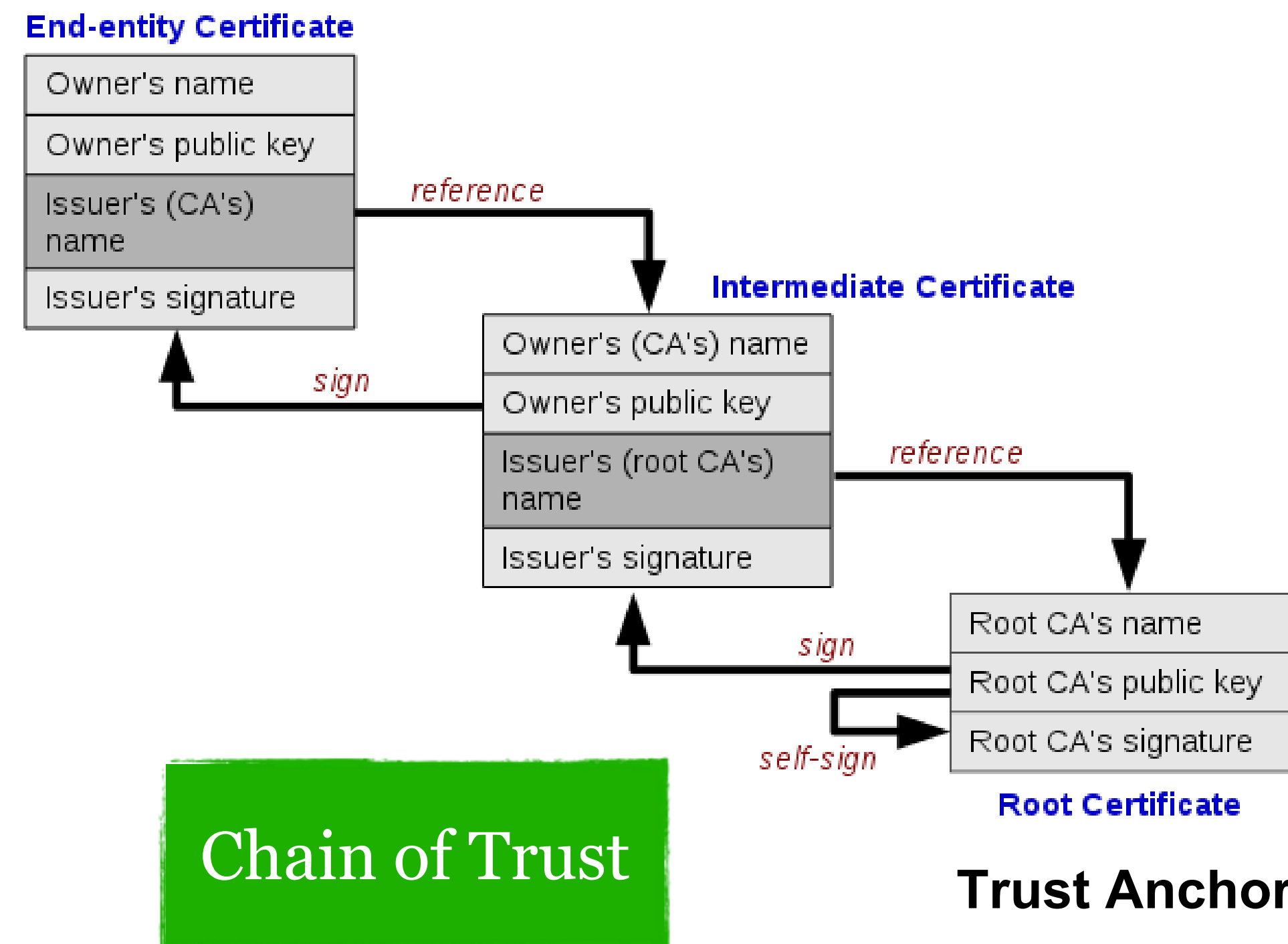
- Name:** DST Root CA X3
- Kind:** Root certificate authority
- Expires:** Thursday, September 30, 2021 at 10:01:15 AM Eastern Daylight Time
- Status:** This certificate is valid
- Trust:** (Expanded)
- Details:**

Field	Value
Subject Name	
Organization	Digital Signature Trust Co.
Common Name	DST Root CA X3
Issuer Name	
Organization	Digital Signature Trust Co.
Common Name	DST Root CA X3
Serial Number	44 AF B0 80 D6 A3 27 BA 89 30 39 86 2E F8 40 6B
Version	3
Signature Algorithm	SHA-1 with RSA Encryption (1.2.840.113549.1.1.5)
Parameters	None
Not Valid Before	Saturday, September 30, 2000 at 5:12:19 PM Eastern Daylight Time
Not Valid After	Thursday, September 30, 2021 at 10:01:15 AM Eastern Daylight Time

Hierarchical Approach

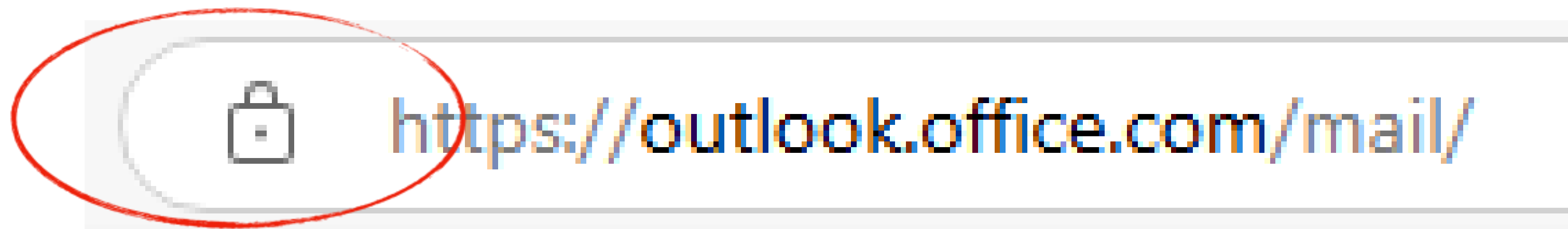
- Single CA certifying every public key is impractical
- Instead, use a trusted **root authority (short for Root CA)**
 - Everybody must know the root's public key
 - Instead of single cert, use a **certificate chain**

$\text{sig}_{\text{DST}}(\text{"AnotherCA"}, \text{PK}_{\text{AnotherCA}}),$
 $\text{sig}_{\text{AnotherCA}}(\text{"Bob"}, \text{PK}_{\text{B}})$



Root CAs go through million dollar audits each year to keep their status.

You encounter this every day...



SSL/TLS: Encryption & authentication for connections

SSL (Secure Sockets Layer) and TLS (Transport Layer Security)

Example: Connecting to Taobao



- Handshake: TCP (unencrypted), then TLS 1.3 (unencrypted)
- Certificate: Alibaba (China) Technology Co., Ltd.
GlobalSign GCC R3 OV TLS CA 2024 (Intermediate)
GlobalSign (Root)
- Verification: Check against list of Root CAs on your PC, using Root's Pk to verify the Intermediate's signature, then uses the Intermediate's Pk to verify Alibaba's signature
- Key Exchange by using the asymmetric encryption discussed before

All happens within the Transport Layer, before log in!

Riot Games SSL Certificate Expired

Their previous SSL certificate expired on 01/04/2026, and did not auto renew. As a result, its games experienced blackout for a few hours. Later they renewed the certificate with an expiration date on 2125.

Issued To		颁发给	
Common Name (CN)	rclient	公用名(CN)	rclient
Organization (O)	<Not Part Of Certificate>	组织(O)	<不是证书的一部分>
Organizational Unit (OU)	<Not Part Of Certificate>	组织单位(OU)	<不是证书的一部分>
Issued By		颁发者	
Common Name (CN)	LoL Game Engineering Certificate Authority	公用名(CN)	LoL Game Engineering Certificate Authority
Organization (O)	Riot Games	组织(O)	Riot Games
Organizational Unit (OU)	LoL Game Engineering	组织单位(OU)	LoL Game Engineering
Validity Period		有效期	
Issued On	Thursday, January 7, 2016 at 9:03:33 PM	颁发日期	2026年1月5日星期一 06:51:53
Expires On	Sunday, January 4, 2026 at 9:03:33 PM	到期日期	2125年12月12日星期三 06:51:53

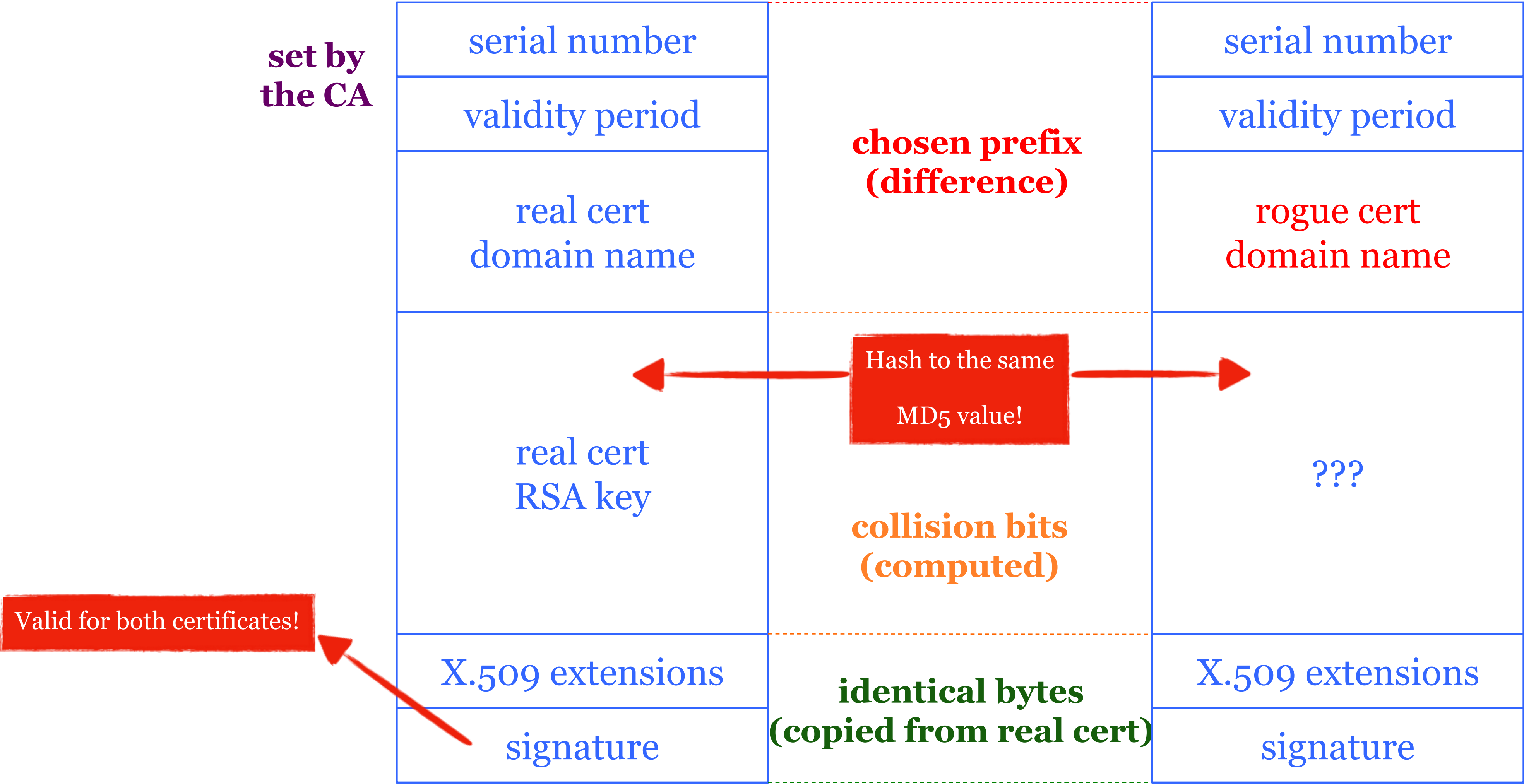
What happens if root authority is ever compromised?

- The entire foundation of internet security for anyone trusting that CA **collapses.**
- Allows attackers to issue rogue certificates for any website
- Users don't notice when attacks happen

Consequences

- Attacker needs to first divert users to an attacker-controlled site instead of Google, Yahoo, Skype, but then...
 - For example, use DNS to poison the mapping of mail.yahoo.com to an IP address
- ... “authenticate” as the real site
- ... decrypt all data sent by users
 - Email, phone conversations, Web browsing

Colliding Certificates



DigiNotar is a Dutch Certificate Authority. They sell SSL certificates.



Attacking CAs

Security of DigiNotar servers:

- All core certificate servers controlled by a single admin password (Prod@dm1n)
- Software on public-facing servers out of date, unpatched
- No anti-virus (could have detected attack)

Somehow, somebody managed to get a rogue SSL certificate from them on **July 10th, 2011**. This certificate was issued for domain name **.google.com**.

What can you do with such a certificate? Well, you can impersonate Google — assuming you can first reroute Internet traffic for google.com to you. This is something that can be done by a government or by a rogue ISP. Such a reroute would only affect users within that country or under that ISP.

More Rogue Certs



- In Jan 2013, a rogue *.google.com certificate was issued by an intermediate CA that gained its authority from the Turkish root CA TurkTrust
 - TurkTrust accidentally issued intermediate CA certs to customers who requested regular certificates
 - Ankara transit authority used its certificate to issue a fake *.google.com certificate in order to filter SSL traffic from its network
- This rogue *.google.com certificate was trusted by every browser in the world

Google Security Blog

The latest news and insights from Google on security and safety on the Internet

Enhancing digital certificate security

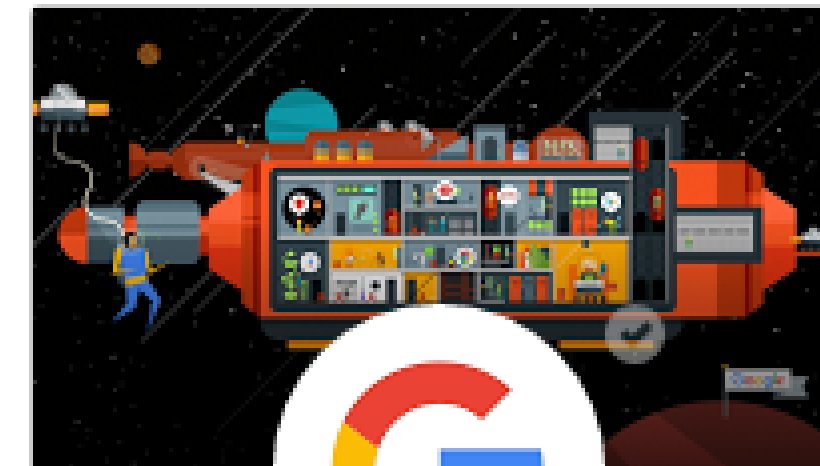
January 3, 2013

Posted by Adam Langley, Software Engineer

Late on December 24, Chrome detected and blocked an unauthorized digital certificate for the "*.google.com" domain. We investigated immediately and found the certificate was issued by an intermediate certificate authority (CA) linking back to TURKTRUST, a Turkish certificate authority. Intermediate CA certificates carry the full authority of the CA, so anyone who has one can use it to create a certificate for any website they wish to impersonate.

In response, we updated Chrome's certificate revocation metadata on

Search blog ...



Google

google.com/+google

News and updates on Google's products, technology and more

[G+ Follow](#)

+1

+ 11,007,947

Attempt to Fix CA Problems: Certificate Transparency

- **Problem:** browsers will think nothing is wrong with a rogue certificate until revoked
- **Goal:** make it impossible for a CA to issue a bad certificate for a domain *without the owner of that domain knowing*
- **Approach:** Auditable certificate logs: if a CA issues a certificate, it must be logged in a public, verifiable website.
- **If the certificate is not in the log, modern versions of Chrome will show "Privacy Error" and refuse to load the page.**

Attempt to Fix CA Problems: Certificate Pinning

- Trust only one (or a few) specific certificate(s).
- When a user connects, the browser checks against the pinned one, and reject if does not match.
- Gold standard for mobile application security.

Certificate Revocation

- Revocation is **very important**
- **Many valid reasons to revoke a certificate**
 - Private key corresponding to the certified public key has been compromised
 - User stopped paying his certification fee to this CA and CA no longer wishes to certify him
 - CA's private key has been compromised!
- **Expiration is a form of revocation, too**
 - Many deployed systems don't bother with revocation
 - Re-issuance of certificates is a big revenue source for certificate authorities

Certificate Revocation Mechanisms

- Certificate revocation list (CRL)
 - CA periodically issues a signed list of revoked certificates
 - Credit card companies used to issue thick books of canceled credit card numbers
 - Can issue a “delta CRL” containing only updates
- Online revocation service
 - When a certificate is presented, recipient goes to a special online service to verify whether it is still valid
 - Like a merchant dialing up the credit card processor